MF0487_3 - AUDITORIA DE SEGURIDAD INFORMATICA

LABORATORIO 5

Auditoria de Cortafuegos

Nmap NSE - hping3 - firewalk

Objetivo: iptables sobre Metasploitable 2

Entorno: 2 maquinas - Kali Linux Purple + Metasploitable 2

Normativa: ENS (mp.com.1, op.exp.1, op.mon.1) - ISO 27001:2022 A.8.20, A.8.22 - MAGERIT v3

Duracion estimada: 4 horas - Nivel: Intermedio - Prerrequisitos: LAB-01, LAB-03

AVISO: Este documento es de uso exclusivo en entornos de laboratorio controlado.

0. FICHA TECNICA DEL LABORATORIO

Codigo	LAB-05	**UD**	UD5
Titulo	Auditoria de Cortafuegos: Verificacion de Reglas y Politica Perimetral	**Duracion**	4 h
Normativa	ENS (mp.com.1, op.exp.1, op.mon.1) - ISO 27001:2022 A.8.20, A.8.22 - MAGERIT v3	**Nivel**	Intermedio
Herramientas	Nmap NSE - hping3 - firewalk - iptables - tcpdump	**Prereq.**	LAB-01, LAB-03
Maquinas	*Kali Linux Purple (auditor) | Metasploitable 2 (host con iptables configurado - simula host detras de firewall)*		
Objetivo	*Auditar la politica de filtrado de paquetes de un cortafuegos Linux (iptables) sobre Metasploitable 2. Identificar puertos abiertos, filtrados y cerrados, inferir las reglas activas, detectar bypasses y evaluar el cumplimiento con los controles perimetrales del ENS e ISO 27001:2022.*		

1. MARCO NORMATIVO - PROTECCION PERIMETRAL

El cortafuegos es el primer control tecnico de la seguridad perimetral. Su configuracion incorrecta es una de las causas mas frecuentes de incidentes de seguridad. Las siguientes referencias exigen auditar explicitamente la politica de filtrado:

1.1 Esquema Nacional de Seguridad - RD 311/2022

* mp.com.1 - Perimetro seguro: en sistemas de categoria MEDIA y ALTA, debe existir un control perimetral que restrinja el trafico a lo estrictamente necesario. El trafico no autorizado debe ser denegado por defecto (politica deny-all). La politica de filtrado debe estar documentada y revisarse periodicamente.
* op.exp.1 - Inventario de activos: el cortafuegos y sus reglas forman parte del inventario de activos de seguridad. Cada regla debe estar justificada por un requisito de negocio.
* op.mon.1 - Deteccion de intrusiones: los logs del cortafuegos son fuente primaria de deteccion. Categoria MEDIA requiere monitorizacion de eventos perimetrales; categoria ALTA requiere SIEM.
* op.exp.4 - Mantenimiento: el firmware y el software del cortafuegos deben mantenerse actualizados. Las reglas obsoletas deben eliminarse periodicamente.

1.2 ISO 27001:2022

* A.8.20 - Seguridad de las redes: las redes deben gestionarse y controlarse para proteger los sistemas y aplicaciones. El cortafuegos es el control tecnico principal.
* A.8.22 - Segregacion de redes: los grupos de servicios, usuarios y sistemas deben estar segregados en redes distintas. La auditoria de firewall verifica que la segmentacion real coincide con la documentada.
* A.8.21 - Seguridad de los servicios de red: los mecanismos de seguridad deben identificarse e incluirse en los SLA. Las reglas de firewall son parte de estos mecanismos.

1.3 MAGERIT v3 - Amenazas relevantes

Amenaza MAGERIT	Cod.	Relacion con la auditoria de firewall
Acceso no autorizado	[A.11]	Reglas permisivas en exceso permiten acceso a servicios que deberian estar restringidos.
Analisis de trafico	[A.12]	Sin cortafuegos, el trafico interno es visible desde el exterior.
Denegacion de servicio	[A.24]	El firewall debe mitigar DoS con rate limiting. La auditoria verifica estas protecciones.
Errores del administrador	[E.2]	Reglas mal definidas (typos en IPs, rangos incorrectos). La auditoria las detecta.
Uso no previsto	[A.7]	Un puerto abierto no justificado indica servicio no autorizado o error de configuracion.

1.4 Tipos de auditoria de cortafuegos

Tipo	Descripcion	Herramientas	Limitacion
Caja negra externa	Se audita desde fuera sin conocer las reglas. Se observa el comportamiento ante diferentes tipos de trafico.	Nmap, hping3, firewalk	No se puede verificar lo que no se envia.
Revision de configuracion	Se audita directamente el ruleset (acceso al sistema).	iptables -L, revision de ficheros	Requiere acceso privilegiado.

Test de penetracion perimetral	Combina caja negra con intento activo de bypass.	hping3, ncat, socat, tuneles	Mas intrusivo; requiere autorizacion explicita.

En este laboratorio se combina la auditoria de caja negra (Tareas 1-5, desde Kali) con la revision directa de configuracion (Tarea 6, acceso SSH a iptables). Esta combinacion es la mas habitual en auditorias reales con acceso al sistema.

2. ENTORNO DE LABORATORIO

2.1 Topologia

Maquina	Rol	IP (anotar)	Notas
Kali Linux Purple	Auditor: lanza las sondas	_____	Nmap, hping3, firewalk, tcpdump
Metasploitable 2	Objetivo: iptables activo simulando host con firewall	_____	Se configura iptables en Tarea 0

2.2 Tarea 0 - Configuracion del escenario iptables en Metasploitable 2

Antes de iniciar la auditoria, el instructor configura iptables en Metasploitable 2 para simular un cortafuegos real con politica mixta. Esta configuracion reproduce un escenario tipico de produccion con algunas reglas incorrectas que el alumno debe detectar.

> **AVISO:** Ejecuta los siguientes comandos desde una sesion SSH a Metasploitable 2 ANTES de comenzar las tareas de auditoria desde Kali. No los consultes durante la auditoria: el objetivo es descubrir las reglas mediante las tecnicas de las tareas siguientes.

```
ssh msfadmin@<IP_META>   # contrasena: msfadmin

# Limpiar reglas existentes
sudo iptables -F && sudo iptables -X && sudo iptables -Z

# Politica por defecto: DENEGAR TODO
sudo iptables -P INPUT DROP
sudo iptables -P FORWARD DROP
sudo iptables -P OUTPUT ACCEPT

# Loopback y conexiones establecidas
sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# Puertos permitidos
sudo iptables -A INPUT -p tcp --dport 22   -j ACCEPT   # SSH
sudo iptables -A INPUT -p tcp --dport 80   -j ACCEPT   # HTTP
sudo iptables -A INPUT -p tcp --dport 443  -j ACCEPT   # HTTPS
sudo iptables -A INPUT -p tcp --dport 21   -j ACCEPT   # FTP  -- regla permisiva a
auditar
sudo iptables -A INPUT -p tcp --dport 23   -j ACCEPT   # TELNET -- regla insegura a
auditar
sudo iptables -A INPUT -p tcp --dport 3306 -j ACCEPT   # MySQL expuesto -- regla
incorrecta
sudo iptables -A INPUT -p tcp --dport 8180 -j ACCEPT   # Tomcat
sudo iptables -A INPUT -p icmp             -j ACCEPT   # ICMP

# Puertos filtrados con DROP silencioso
sudo iptables -A INPUT -p tcp --dport 445  -j DROP     # SMB filtrado
sudo iptables -A INPUT -p tcp --dport 6667 -j DROP     # IRC filtrado
```

```
sudo iptables -L -n -v --line-numbers
exit
```

> **i** Esta configuracion mezcla deliberadamente reglas correctas (SSH, HTTP) con reglas problematicas (Telnet, MySQL expuesto, FTP sin restriccion de origen) que el auditor debera identificar. El alumno no conoce estas reglas durante la auditoria de caja negra.

2.3 Verificacion de herramientas en Kali

```
nmap --version | head -1
hping3 --version 2>&1 | head -1
which firewalk || sudo apt install -y firewalk
mkdir -p ~/lab05
```

3. OBJETIVOS DE APRENDIZAJE

* Comprender las diferencias entre puerto OPEN, CLOSED y FILTERED desde la perspectiva de la auditoria de cortafuegos.
* Aplicar tecnicas de escaneo avanzado con Nmap (SYN, ACK, FIN, XMAS, NULL, UDP, Window scan) para inferir reglas de firewall.
* Usar hping3 para enviar sondas TCP/UDP/ICMP personalizadas y analizar respuestas a nivel de paquete.
* Aplicar firewalk para determinar que puertos atraviesan el cortafuegos usando TTL.
* Detectar reglas permisivas en exceso, puertos innecesariamente expuestos y ausencia de control de estado.
* Revisar directamente el ruleset iptables y evaluar su conformidad con la politica ENS.
* Documentar cada hallazgo con la tecnica usada, evidencia obtenida y control ENS / ISO 27001 incumplido.

4. DESARROLLO DEL LABORATORIO

TAREA 1 - Mapa inicial de puertos: OPEN / CLOSED / FILTERED (30 min)

El primer paso de la auditoria es establecer el mapa completo de puertos. Nmap distingue tres estados fundamentales:

Estado Nmap	Significado	Respuesta del sistema	Implicacion para el firewall
OPEN	Puerto abierto - servicio activo	SYN-ACK (TCP) / dato UDP	El firewall permite el trafico a este puerto.
CLOSED	Puerto cerrado - sin servicio	RST-ACK (TCP) / ICMP Port Unreach.	El firewall deja pasar pero no hay servicio escuchando.
FILTERED	Firewall bloquea el trafico	Sin respuesta (DROP) o ICMP admin-prohibited	Hay una regla DROP o REJECT para este puerto.

1.1 SYN scan - escaneo estandar

```
# SYN scan de los 1000 puertos mas comunes
sudo nmap -sS -sV --open <IP_META> -oN ~/lab05/nmap_syn.txt

# SYN scan completo de los 65535 puertos (5-10 min)
sudo nmap -sS -p- <IP_META> -oN ~/lab05/nmap_syn_full.txt

# Ver solo los puertos OPEN y FILTERED
grep -E '^[0-9]|open|filtered' ~/lab05/nmap_syn.txt
```

1.2 UDP scan - servicios no TCP

```
sudo nmap -sU --top-ports 50 <IP_META> -oN ~/lab05/nmap_udp.txt
```

TIP: El escaneo UDP es mucho mas lento que TCP: los puertos filtrados no responden y Nmap espera el timeout completo. Limita a --top-ports 50 para el laboratorio.

1.3 Mapa inicial de puertos - tabla de resultados

Puerto	Proto	Estado Nmap	Servicio detectado	Esperado?	Observaciones
21	TCP	_____	FTP (vsftpd)	_____	_____
22	TCP	_____	SSH (OpenSSH)	_____	_____
23	TCP	_____	Telnet	_____	_____
25	TCP	_____	SMTP	_____	_____
53	TCP/UDP	_____	DNS	_____	_____
80	TCP	_____	HTTP (Apache)	_____	_____
139	TCP	_____	NetBIOS	_____	_____
443	TCP	_____	HTTPS	_____	_____
445	TCP	_____	SMB	_____	_____

3306	TCP	_____	MySQL	_____	_____
5432	TCP	_____	PostgreSQL	_____	_____
6667	TCP	_____	IRC	_____	_____
8180	TCP	_____	Tomcat	_____	_____

> **i** La columna 'Esperado?' se completa comparando con la politica ENS: solo los puertos estrictamente necesarios deben estar abiertos. Un puerto OPEN no esperado es un hallazgo de auditoria.

TAREA 2 - Inferencia de reglas con Nmap ACK, FIN y Window scan (30 min)

Los escaneos avanzados permiten distinguir entre DROP y REJECT, detectar firewalls stateless, y en algunos casos determinar el estado real de puertos que aparecen FILTERED en el SYN scan.

2.1 ACK scan - detectar si el firewall tiene estado (stateful)

El ACK scan envia paquetes con flag ACK sin SYN previo. Un firewall stateless responde con RST porque no tiene contexto. Un firewall stateful descarta el paquete porque no pertenece a ninguna conexion conocida.

```
sudo nmap -sA <IP_META> -p 22,80,443,21,23,445,3306 -oN ~/lab05/nmap_ack.txt
# UNFILTERED = firewall stateless o sin regla para ACK
# FILTERED   = firewall stateful o regla DROP para ACK
```

Puerto	SYN scan	ACK scan	Inferencia del tipo de firewall
22	_____	_____	_____
80	_____	_____	_____
23	_____	_____	_____
445	_____	_____	_____
3306	_____	_____	_____
6667	_____	_____	_____

2.2 FIN, XMAS y NULL scan - evasion de firewalls stateless

Estos escaneos explotan el RFC 793: puertos cerrados responden RST, puertos abiertos ignoran estos paquetes. Un firewall stateless que solo filtra SYN no los bloqueara.

```
sudo nmap -sF <IP_META> -p 22,80,23,445,3306,6667 -oN ~/lab05/nmap_fin.txt
sudo nmap -sX <IP_META> -p 22,80,23,445,3306,6667 -oN ~/lab05/nmap_xmas.txt
sudo nmap -sN <IP_META> -p 22,80,23,445,3306,6667 -oN ~/lab05/nmap_null.txt
```

Puerto	FIN scan	XMAS scan	NULL scan	Conclusion
22	_____	_____	_____	_____
80	_____	_____	_____	_____
23	_____	_____	_____	_____
445	_____	_____	_____	_____
3306	_____	_____	_____	_____
6667	_____	_____	_____	_____

2.3 Window scan

```
sudo nmap -sW <IP_META> -p 1-1024 -oN ~/lab05/nmap_window.txt
```

TAREA 3 - Analisis a nivel de paquete con hping3 (50 min)

hping3 permite construir paquetes TCP/UDP/ICMP a medida y analizar las respuestas campo a campo. Es la herramienta de referencia para entender exactamente como reacciona el firewall ante cada tipo de trafico.

3.1 Flags hping3 de referencia

Flag	Significado	Uso habitual en auditoria de FW
-S	Flag SYN activo	Simular inicio de conexion TCP
-A	Flag ACK activo	Detectar firewalls stateful
-F	Flag FIN activo	Evasion de firewalls stateless
-p <puerto>	Puerto destino	Especificar el puerto a sondear
--udp	Modo UDP	Sondas UDP
--icmp	Modo ICMP	Sondas ICMP personalizadas
-c <n>	Numero de paquetes	Limitar la cantidad de sondas
--ttl <n>	TTL personalizado	Tecnica firewalk manual
-V	Verbose	Ver contenido de los paquetes de respuesta

3.2 Sondas SYN - comportamiento basico

```
# Puerto abierto - esperar SYN-ACK (flags=SA)
sudo hping3 -S -p 80 -c 3 <IP_META>

# Puerto filtrado con DROP - esperar timeout, sin respuesta
sudo hping3 -S -p 445 -c 3 <IP_META>

# Puerto cerrado con RST - esperar RST-ACK (flags=RA)
sudo hping3 -S -p 9999 -c 3 <IP_META>

# Telnet y MySQL - auditar accesibilidad
sudo hping3 -S -p 23 -c 3 -V <IP_META>
sudo hping3 -S -p 3306 -c 3 -V <IP_META>
```

Puerto	flags=	rtt (ms)	Interpretacion
80	_____	_____	_____
445	_____	_____	_____
9999	_____	_____	_____
23	_____	_____	_____
3306	_____	_____	_____

3.3 Sondas ACK - stateful vs. stateless

```
sudo hping3 -A -p 80 -c 3 -V <IP_META>
sudo hping3 -A -p 445 -c 3 -V <IP_META>
sudo hping3 -A -p 9999 -c 3 -V <IP_META>
```

> **FW:** Si hping3 -A a un puerto abierto recibe RST, el firewall es STATELESS. Si no recibe nada, es STATEFUL. Un firewall stateless es mas debil frente a tecnicas de evasion con paquetes ACK o fragmentados.

3.4 Sondas ICMP - politica de filtrado ICMP

```
# ICMP Echo Request (tipo 8) - ping estandar
sudo hping3 --icmp -c 3 <IP_META>

# ICMP Timestamp Request (tipo 13) - puede revelar hora del sistema
sudo hping3 --icmp --icmp-type 13 -c 3 <IP_META>

# ICMP Address Mask Request (tipo 17) - puede revelar mascara de red
sudo hping3 --icmp --icmp-type 17 -c 3 <IP_META>
```

Responde el firewall al tipo 13 (Timestamp)? _____ Al tipo 17? _____

3.5 DROP vs. REJECT: medir tiempo de respuesta

```
time sudo hping3 -S -p 445  -c 1 <IP_META>   # Puerto con DROP
time sudo hping3 -S -p 9999 -c 1 <IP_META>   # Puerto cerrado (RST)
```

Tiempo respuesta puerto 445 (DROP): _____ ms | Puerto 9999 (CLOSED): _____ ms
Conclusion - el firewall usa DROP o REJECT para puertos filtrados: _____

TAREA 4 - Firewalk: que puertos atraviesan el gateway (30 min)

Firewalk usa TTL para determinar que puertos atraviesan un cortafuegos o router intermedio, sin completar la conexion con el host destino. Si el paquete es reenviado por el firewall, el siguiente salto devuelve ICMP TTL Exceeded.

4.1 Principio de funcionamiento

1. Fase 1 - Ramping: paquetes con TTL incremental hasta obtener ICMP TTL Exceeded del gateway. El TTL resultante es el que se usara en la fase 2.
2. Fase 2 - Scanning: paquetes con ese TTL exacto a cada puerto. Si el firewall permite el paso, llegara al siguiente hop y recibimos ICMP TTL Exceeded de ese hop. Si bloquea, no recibimos nada.

> **FW:** Firewalk prueba si el FIREWALL permite el PASO del paquete, no si el puerto esta abierto en el host destino. Es util para auditar reglas de reenvio (FORWARD) y accesos a traves de cortafuegos cuando el host no es directamente accesible.

4.2 Ejecutar firewalk

```
sudo firewalk -S 21,22,23,80,443,445,3306,6667,8180 -i <IFACE> <IP_META> <IP_META>


# Alternativa manual con hping3 y TTL controlado
sudo hping3 -S -p 80 --ttl 1 -c 1 <IP_META>   # TTL=1: responde el primer hop
sudo hping3 -S -p 80 --ttl 2 -c 1 <IP_META>   # Incrementar hasta llegar al
objetivo
```

4.3 Tabla de resultados firewalk

Puerto	Resultado firewalk	Significado	Coherente con Nmap SYN?
21 (FTP)	_____	_____	_____
22 (SSH)	_____	_____	_____
23 (Telnet)	_____	_____	_____
80 (HTTP)	_____	_____	_____
443 (HTTPS)	_____	_____	_____
445 (SMB)	_____	_____	_____
3306 (MySQL)	_____	_____	_____
6667 (IRC)	_____	_____	_____
8180 (Tomcat)	_____	_____	_____

TAREA 5 - Scripts NSE de auditoria de firewall (30 min)

5.1 firewall-bypass - detectar reglas eludibles

```
sudo nmap --script firewall-bypass <IP_META>
sudo nmap --script firewall-bypass --script-args firewall-bypass.target-port=3306
<IP_META>
```

5.2 firewalk NSE

```
sudo nmap --script firewalk --traceroute <IP_META>
```

5.3 Deteccion de sistema zombie (IPID idle scan)

```
sudo nmap --script ipidseq <IP_META>
# Si responde 'incremental': puede usarse como zombie en idle scan anonimo
```

5.4 Source port bypass - reglas que confian en el puerto origen

Algunos firewalls mal configurados permiten trafico originado desde el puerto 53 (DNS). Esta regla puede ser explotada para acceder a servicios filtrados:

```
# Scan usando puerto origen 53
sudo nmap -sS --source-port 53 -p 445,3306,6667 <IP_META>

# Con hping3 - SYN desde puerto origen 53
sudo hping3 -S -p 445 --baseport 53 -c 3 -V <IP_META>
```

Cambia el estado de algun puerto filtrado al usar source port 53? _____

> **FW:** Si un puerto FILTERED pasa a OPEN con source port 53, el firewall tiene una regla que confia en el puerto de origen sin validar el estado de la conexion. Misconfiguration clasica de firewalls stateless. Documentar como hallazgo F-03 o adicional.

```
# Exportar todos los resultados NSE
sudo nmap --script firewall-bypass,firewalk -p 1-1024 <IP_META> \
  -oX ~/lab05/nmap_fw_scripts.xml -oN ~/lab05/nmap_fw_scripts.txt
```

TAREA 6 - Revision directa del ruleset iptables (30 min)

La revision directa del ruleset es el complemento de la caja negra: permite verificar si las reglas son las esperadas segun la politica de seguridad, identificar reglas redundantes u obsoletas y calcular el gap entre la politica documentada y la configuracion real.

6.1 Acceso SSH y volcado de reglas

```
ssh msfadmin@<IP_META>

# Listar reglas con contadores de paquetes y bytes
sudo iptables -L -n -v --line-numbers

# Exportar ruleset completo en formato restaurable
sudo iptables-save | tee /tmp/iptables_actual.txt
exit

# Copiar el ruleset a Kali
scp msfadmin@<IP_META>:/tmp/iptables_actual.txt ~/lab05/iptables_actual.txt
```

6.2 Analisis del ruleset - conformidad ENS

N. regla	Protocolo	Puerto	Accion	Justificada?	Conformidad ENS	Observacion
INPUT 1	TCP	22	ACCEPT	Si - gestion remota	CONFORME	SSH cifrado: correcto
INPUT 2	TCP	80	ACCEPT	Si - servicio web	CONFORME	HTTP necesario - evaluar necesidad de HTTPS
INPUT 3	TCP	443	ACCEPT	Si - web cifrado	CONFORME	Correcto
INPUT 4	TCP	21	ACCEPT	Revisar	_____	FTP texto claro - necesario? sin restriccion origen?
INPUT 5	TCP	23	ACCEPT	NO	NO CONFORME	Telnet en texto claro: violacion directa mp.com.2
INPUT 6	TCP	3306	ACCEPT	NO	NO CONFORME	MySQL expuesto a toda la red: solo deberia ser localhost
INPUT 7	TCP	8180	ACCEPT	Revisar	_____	Tomcat - necesario desde el exterior?
INPUT 8	ICMP	---	ACCEPT	Si	CONFORME	ICMP necesario para diagnostico de red
INPUT 9	TCP	445	DROP	Si	CONFORME	SMB no debe ser accesible desde exterior
INPUT 10	TCP	6667	DROP	Si	CONFORME	IRC no debe ser accesible desde exterior
Politica	ALL	ALL	DROP	Si	CONFORME	Politica deny-all correcta

6.3 Verificar politica por defecto

```
ssh msfadmin@<IP_META> 'sudo iptables -L | head -5'
```

Politica INPUT: _____ OUTPUT: _____ FORWARD: _____

TAREA 7 - Documentacion de hallazgos de firewall (30 min)

Se incluyen tres hallazgos modelo. El alumno debe completar al menos dos adicionales.

F-01 Telnet habilitado en el firewall - puerto 23 OPEN	
Control ENS incumplido	ENS mp.com.2 - Cifrado de las comunicaciones (INCUMPLIMIENTO DIRECTO)
Tecnica de auditoria	Nmap SYN scan (confirmado) - hping3 SYN probe (flags=SA) - Revision directa iptables
Descripcion del hallazgo	El firewall tiene una regla ACCEPT explicita para el puerto TCP 23 (Telnet). El servicio Telnet esta activo y accesible desde cualquier origen sin restriccion. El LAB-03 confirmo que las credenciales de autenticacion se transmiten en texto claro y son capturables con Wireshark.
Comandos de verificacion	`sudo nmap -sS -p 23 <IP_META> [23/tcp open telnet] | sudo hping3 -S -p 23 -c 3 -V <IP_META> [flags=SA]`
Evidencia requerida	Captura Nmap: 23/tcp open. Captura hping3 con flags=SA. Captura Wireshark (LAB-03) con credenciales en claro. Linea iptables: -A INPUT -p tcp --dport 23 -j ACCEPT.
Impacto / Riesgo	Cualquier atacante con acceso a la red puede capturar las credenciales de administracion transmitidas por Telnet. Violacion directa del control ENS mp.com.2 y ISO 27001:2022 A.8.24. MAGERIT: Amenaza [A.5] dimension C.
Recomendacion	Eliminar la regla: iptables -D INPUT -p tcp --dport 23 -j ACCEPT. Deshabilitar el servicio: systemctl disable telnet --now. Sustituir por SSH para toda gestion remota.
Referencia normativa	ENS: mp.com.2 (INCUMPLE). ISO 27001:2022 A.8.24. MAGERIT v3 [A.5] dimension C. CCN-STIC 817.

F-02 MySQL expuesto en red - puerto 3306 OPEN sin restriccion de origen	
Control ENS incumplido	ENS mp.com.1 - Perimetro seguro (el trafico a BD no debe ser accesible desde exterior)
Tecnica de auditoria	Nmap SYN scan (-sV) - hping3 SYN probe - Revision directa iptables - Verificacion acceso MySQL
Descripcion del hallazgo	El firewall permite conexiones TCP al puerto 3306 (MySQL) desde cualquier origen sin restriccion de IP. Combinado con el hallazgo del LAB-02 (MySQL root sin contrasena), cualquier host de la red puede conectarse a la base de datos como root sin autenticacion. La base de datos es la segunda linea de defensa: si el firewall la expone y no tiene contrasena, no hay ninguna defensa.
Comandos de verificacion	`sudo nmap -sS -sV -p 3306 <IP_META> [3306/tcp open mysql] | mysql -h <IP_META> -u root [acceso sin contrasena]`
Evidencia requerida	Captura Nmap con 3306/tcp open y version MySQL. Captura hping3 confirmando accesibilidad. Captura de sesion MySQL exitosa sin contrasena. Linea iptables: -A INPUT -p tcp --dport 3306 -j ACCEPT.
Impacto / Riesgo	Acceso sin autenticacion a todas las bases de datos del sistema. Si hay datos personales: brecha notificable a la AEPD. MAGERIT: [A.11] Acceso no autorizado + [A.6] Abuso de privilegios. Dimensiones C e I.
Recomendacion	Restringir puerto 3306 a localhost: iptables -D INPUT -p tcp --dport 3306 -j ACCEPT && iptables -A INPUT -p tcp --dport 3306 -s 127.0.0.1 -j ACCEPT. Establecer contrasena root MySQL. Crear usuarios de BD con minimos privilegios.
Referencia normativa	ENS: mp.com.1 (INCUMPLE). ISO 27001:2022 A.8.20, A.8.22. RGPD art. 32. MAGERIT v3 [A.11], [A.6].

F-03 Firewall stateless - vulnerable a evasion con paquetes ACK/FIN	
Control ENS incumplido	ENS op.exp.1 - Configuracion de seguridad inadecuada del cortafuegos
Tecnica de auditoria	Nmap ACK scan (-sA) - hping3 -A - Nmap FIN/XMAS/NULL scans
Descripcion del hallazgo	El ACK scan devuelve UNFILTERED en puertos que el SYN scan marca como OPEN, indicando que el firewall no realiza inspeccion de estado (stateless). Un firewall stateless aplica reglas solo en base a cabeceras individuales sin recordar el contexto de conexion. Esto permite evasion con paquetes ACK, FIN, RST y fragmentados que no contienen el flag SYN.
Comandos de verificacion	`sudo nmap -sA <IP_META> -p 80,22,23 [UNFILTERED en puertos abiertos] | sudo hping3 -A -p 80 -c 3 -V <IP_META> [recibe RST en lugar de timeout]`
Evidencia requerida	Captura Nmap -sA mostrando UNFILTERED. Captura hping3 -A con respuesta RST. Comparativa de tiempos DROP vs CLOSED de la Tarea 3.5.
Impacto / Riesgo	Un firewall stateless puede ser evadido con paquetes ACK o fragmentados para acceder a servicios internos. Reduce significativamente la proteccion perimetral. MAGERIT: [A.11] + [E.2].
Recomendacion	Anadir regla stateful antes de las reglas especificas: iptables -I INPUT 1 -m state --state ESTABLISHED,RELATED -j ACCEPT. Verificar modulo conntrack: lsmod | grep conntrack. Considerar migracion a nftables.
Referencia normativa	ENS: op.exp.1 (Configuracion de seguridad). ISO 27001:2022 A.8.20. MAGERIT v3 [E.2].

Hallazgos F-04 y F-05 - A completar por el alumno:

Campo	F-04 (completar)	F-05 (completar)
Titulo del hallazgo	_____	_____
Control ENS incumplido	_____	_____
Tecnica de auditoria	_____	_____
Descripcion	_____	_____
Comandos usados	_____	_____
Evidencia obtenida	_____	_____
Impacto / Riesgo	_____	_____
Recomendacion	_____	_____
Referencia normativa	_____	_____

5. ENTREGABLE - INFORME DE AUDITORIA DE CORTAFUEGOS

5.1 Estructura del informe

* 1. Portada: datos del alumno, fecha, sistema auditado, tipo de auditoria (caja negra + revision de configuracion).
* 2. Alcance y metodologia: herramientas, tecnicas de escaneo, referencia ENS mp.com.1.
* 3. Resumen ejecutivo: politica del firewall observada, hallazgos principales, recomendacion urgente.
* 4. Mapa de puertos completo: tabla de la Tarea 1.3 completada.
* 5. Analisis de tipo de firewall: stateful vs. stateless, conclusiones de Tareas 2 y 3.
* 6. Fichas de hallazgos F-01 a F-05.
* 7. Revision del ruleset iptables: tabla de la Tarea 6.2 con columna de conformidad ENS.
* 8. Plan de remediacion: modificaciones iptables necesarias y justificacion normativa.
* 9. Conclusiones: valoracion global y cumplimiento ENS mp.com.1.
* 10. Anexos: ficheros nmap_*.txt/xml, iptables_actual.txt.

5.2 Plan de remediacion iptables

Prior.	Hallazgo	Comando de correccion	Norma	Plazo
1	F-01 Telnet OPEN	iptables -D INPUT -p tcp --dport 23 -j ACCEPT && systemctl disable telnet	ENS mp.com.2	Inmediato
1	F-02 MySQL expuesto	iptables -D INPUT -p tcp --dport 3306 -j ACCEPT && iptables -A INPUT -p tcp -s 127.0.0.1 --dport 3306 -j ACCEPT	ENS mp.com.1	Inmediato
2	F-03 Firewall stateless	iptables -I INPUT 1 -m state --state ESTABLISHED,RELATED -j ACCEPT	ENS op.exp.1	7 dias
2	F-04 (alumno)	_____	_____	_____
3	F-05 FTP sin restriccion origen	iptables -D INPUT -p tcp --dport 21 -j ACCEPT && iptables -A INPUT -p tcp --dport 21 -s <RANGO_OK> -j ACCEPT	ENS mp.com.1	30 dias

5.3 Ficheros a entregar

```
zip LAB05_[apellido]_[nombre].zip ~/lab05/
```

Fichero	Contenido
nmap_syn.txt	SYN scan inicial - mapa de puertos base
nmap_syn_full.txt	SYN scan completo 65535 puertos
nmap_ack.txt	ACK scan - analisis stateful/stateless
nmap_fin.txt / nmap_xmas.txt / nmap_null.txt	Escaneos avanzados de evasion
nmap_fw_scripts.txt / .xml	Scripts NSE firewall-bypass y firewalk
iptables_actual.txt	Volcado del ruleset iptables (iptables-save)
informe_lab05.pdf	Informe completo de auditoria de cortafuegos

6. PREGUNTAS DE REFLEXION

* Has detectado que iptables tiene politica DROP en INPUT pero permite explicitamente el puerto 23 (Telnet). Desde el punto de vista del ENS (mp.com.1 y mp.com.2), cual de los dos incumplimientos es mas grave: tener la politica por defecto en ACCEPT o tener Telnet explicitamente permitido? Podria uno compensar al otro?
* La diferencia entre un firewall STATEFUL y uno STATELESS es fundamental para la seguridad perimetral. Describe un escenario concreto de ataque en el que un atacante podria evadir un firewall stateless pero NO uno stateful, usando solo las herramientas practicadas (hping3 o Nmap).
* Firewalk usa TTL para inferir las reglas del firewall sin completar la conexion con el host destino. Que implicacion tiene esto para la deteccion por un IDS/IPS? Es firewalk detectable por un IDS basado en firmas como Snort? Y por uno basado en anomalias de comportamiento?
* El ENS (mp.com.1) exige que el trafico no autorizado sea denegado por defecto. En el ruleset revisado, MySQL esta expuesto en la red. Si este servidor alojara datos de caracter personal: que articulos del RGPD estarian incumplidos? Que medidas tecnicas minimas exige el art. 32 del RGPD para proteger esos datos?
* iptables es la solucion de firewall tradicional de Linux. Su sucesor nftables ofrece mejor rendimiento y gestion de reglas. Investiga que ventajas tecnicas tiene nftables sobre iptables en terminos de gestion de estado, rendimiento y sintaxis. Cambiaria tu informe alguna de las recomendaciones de la Tarea 7?

7. RUBRICA DE EVALUACION

Criterio	Insuficiente (0-4)	Suficiente (5-7)	Excelente (8-10)
Uso de herramientas (25%)	Solo Nmap basico, sin hping3 ni firewalk	Nmap con multiples tecnicas y hping3 ejecutado	Nmap NSE, hping3 y firewalk ejecutados con opciones justificadas
Mapa de puertos y analisis de reglas (30%)	Tabla de puertos incompleta o con errores	Tabla completa con estados open/filtered/closed	Tabla completa con inferencia justificada de las reglas iptables
Deteccion de bypasses y anomalias (25%)	No identifica ningun bypass	Identifica al menos un bypass o anomalia	Documenta multiples tecnicas de evasion con evidencia y referencia ENS
Informe de auditoria de firewall (20%)	Sin estructura normativa o incompleto	Estructura basica con hallazgos principales	Informe profesional con hallazgos vinculados a controles ENS e ISO 27001

Nota final: media ponderada de los cuatro criterios. Nota minima de 5 en cada criterio para superar el laboratorio.

> **i** El mapa de puertos y el analisis de politica de filtrado de este laboratorio se integraran en el LAB-07 (Analisis de riesgos MAGERIT) como parte del analisis de salvaguardas perimetrales. El fichero iptables_actual.txt es evidencia de auditoria. Conservalo.

8. REFERENCIAS

Normativa

* Real Decreto 311/2022 - ENS. Medidas mp.com.1 (Perimetro seguro), op.exp.1 (Inventario), op.mon.1 (Deteccion de intrusiones). BOE num. 106, 2022.
* ISO/IEC 27001:2022. Controles A.8.20 (Seguridad de redes), A.8.22 (Segregacion), A.8.21 (Servicios de red).
* CCN-CERT. MAGERIT v3. Libro II: Amenazas [A.7], [A.11], [A.12], [A.24], [E.2]. Madrid: MINHAP, 2012.
* CCN-STIC 408 - Seguridad Perimetral: Cortafuegos. Centro Criptologico Nacional.

Tecnicas

* Fyodor. Nmap Network Scanning - Cap. 5: Port Scanning Techniques. https://nmap.org/book/man-port-scanning-techniques.html
* Salvatore Sanfilippo. hping3 man page. https://linux.die.net/man/8/hping3
* Hobbit & Renaud Deraison. Firewalk - A Tool for Determining Firewall Policy. Phrack Magazine vol. 8, num. 53, 1999.
* Nmap NSE Scripts: firewall-bypass, firewalk, ipidseq. https://nmap.org/nsedoc/
* Linux Netfilter Project. iptables y nftables. https://netfilter.org/
* IETF RFC 793 - Transmission Control Protocol. Postel, 1981.